

Policy_ID: CIP-RCA-005

Policy_Name: Regulatory Compliance & Audit Control Standard

Version: 1.1

Effective_Date: 2025-12-05

Risk_Category: Legal & Governance

Applicable_Regulations: [SOX, GDPR, PCI-DSS, ISO 27001, COSO, NIST CSF]

Owner: Corporate Compliance & Governance

Regulatory Compliance & Audit Control Standard

1. Purpose & Scope [Risk Score: 1]

This standard establishes a uniform framework to ensure Capstone adheres to all statutory, regulatory, and contractual obligations. It applies to all business units, subsidiaries, and operational systems subject to oversight.

- **Frameworks:** Capstone utilizes **COSO** and **NIST Cybersecurity Framework** for compliance assurance.

2. Regulatory Requirements [Risk Score: 5]

Capstone must comply with the following mandates based on geography and operation:

- **Data & Privacy:** GDPR, DPDPA (India), CCPA/CPRA.
- **Financial:** SOX (Sarbanes-Oxley), PCI-DSS (Payment Processing).
- **Healthcare:** HIPAA/HITECH.
- **Security:** ISO 27001/27701.

Non-Compliance Impact: Failure to maintain an updated regulatory inventory or ignoring a statutory mandate is a **Critical Risk** violation resulting in legal sanctions and financial penalties.

3. Risk Management & Controls [Risk Score: 4]

- **Risk Register:** All compliance risks must be documented in the Enterprise Risk Register.

- **Updates:** Risk ratings must be updated **Quarterly** or upon significant business change.
- **Control Owners:** Must validate control effectiveness periodically.

Non-Compliance Impact: Failure to identify or mitigate a known high-risk area is a **High Risk** governance failure leading to potential operational paralysis.

4. Audit Procedures [Risk Score: 4]

Internal and External audits shall follow:

- **Calendar:** Adherence to the Annual Audit Calendar.
- **Evidence:** All findings must be validated with tamper-proof evidence.
- **Remediation:** Formal remediation plans with deadlines are mandatory for all findings.

Non-Compliance Impact: Obstructing an audit or falsifying evidence is a **High Risk** violation that may result in immediate termination and legal prosecution.

5. Reporting & Escalation [Risk Score: 5]

- **Breach Reporting:** Compliance breaches must be reported to the Compliance Office within **24 hours**.
- **Escalation:** High-severity findings require immediate Executive Committee escalation.
- **Dashboards:** Monthly compliance dashboards must be reviewed by business heads.

Non-Compliance Impact: Late reporting of a compliance breach (e.g., >24 hours) often triggers statutory fines (e.g., GDPR 72-hour rule) and is a **Critical Risk**.

6. Third-Party Compliance [Risk Score: 4]

- **Assessment:** Vendors must be assessed for compliance maturity prior to onboarding.
- **Contractual Clauses:** Vendors must sign specific compliance adherence clauses.
- **Suspension:** Non-compliant vendors may be suspended or terminated immediately.

Non-Compliance Impact: Engaging a vendor without a compliance assessment is a **High Risk** violation of Third-Party Risk Management (TPRM) protocols.

7. Documentation & Evidence [Risk Score: 3]

- **Repository:** Evidence must be stored in a centralized, access-controlled repository.
- **Retention:** Must follow legal mandates (e.g., 7 years for financial records).
- **Audit Trails:** All logs must be preserved for regulator inspection.

Non-Compliance Impact: Loss of compliance evidence due to poor archiving is a **Medium Risk** violation that compromises audit readiness.

8. Non-Compliance & Penalties [Risk Score: 3]

Non-compliance actions may include:

- Disciplinary action up to termination.
- Financial penalties levied against specific business units.
- Temporary suspension of business operations.

Non-Compliance Impact: Repeated negligence regarding compliance standards is a **High Risk** performance issue.